doi: 10.47002/metik.v9i1.1030

METIK JURNAL VOLUME. 9 NOMOR.1 2025 ISSN-P 2442-9562 ISSN-E 2580-1503

Penetration Testing Website E-Journals Metode NIST SP 800-115 dan OWASP

Mifthahuddin[1], Hario Jati Setyadi[2*], Muhammad Rivani Ibrahim[3]

[1,2,3]*Sistem Informasi, Universitas Mulawarman, Indonesia*

[*]hariojati.setyadi@ft.unmul.ac.id

Abstract

The development of information technology has encouraged the digitization of scientific publications through e-journals, which facilitate access and distribution of scientific papers online. Mulawarman University uses Open Journal Systems (OJS) as a publication platform but still relies on version 2 which has several security gaps. This research aims to analyse the level of security vulnerabilities on the e-journals website of Mulawarman University using the penetration testing method based on NIST SP 800-115 and OWASP Top 10 parameters in 2021. This method includes four main stages: planning, discovery, attack, and reporting. Testing was conducted using various tools to identify and validate security holes. The results found 27 vulnerabilities, consisting of 1 high risk, 6 medium risk, 13 low risk, and 7 informational. Some of the main vulnerabilities that were successfully validated include Cross-Site Scripting, Clickjacking, Session Hijacking, Information Disclosure, and Cross-Site Request Forgery. These findings indicate significant weaknesses in access control, security configuration, and session management. Each vulnerability was analysed to understand its impact on data integrity and confidentiality. Proposed remediation recommendations include strengthening security header configuration, input/output validation, and removal of unnecessary system information. This research provides empirical insight into specific vulnerabilities in OJS version 2 at Mulawarman University, which has never conducted penetration testing with a framework using international standards, which is an original contribution to efforts to improve the security of academic publication systems.

Keywords: penetration testing, owasp top 10 , nist sp 800-115, security website, e-journals

Abstrak

Perkembangan teknologi informasi telah mendorong digitalisasi publikasi ilmiah melalui *e-journals*, yang memudahkan akses dan distribusi karya ilmiah secara daring. Universitas Mulawarman menggunakan *Open Journal Systems* (OJS) sebagai *platform* publikasi, namun masih mengandalkan versi 2 yang memiliki sejumlah celah keamanan. Penelitian ini bertujuan menganalisis tingkat kerentanan keamanan pada *website e-journals* Universitas Mulawarman dengan metode *penetration testing* berdasarkan NIST SP 800-115 dan parameter OWASP *Top* 10 tahun 2021. Metode ini meliputi empat tahap utama: perencanaan, penemuan, serangan, dan pelaporan. Pengujian dilakukan menggunakan berbagai *tools* untuk mengidentifikasi dan memvalidasi celah keamanan. Hasilnya ditemukan 27 kerentanan, terdiri dari 1 risiko tinggi, 6 risiko sedang, 13 risiko rendah, dan 7 bersifat informasional. Beberapa kerentanan utama yang berhasil divalidasi antara lain *Cross-Site Scripting*, *Clickjacking*, *Session Hijacking*, *Information Disclosure*, dan *Cross-Site Request Forgery*. Temuan ini mengindikasikan kelemahan signifikan dalam kontrol akses, konfigurasi keamanan, serta pengelolaan sesi. Analisis dilakukan terhadap setiap kerentanan untuk memahami dampaknya terhadap integritas dan kerahasiaan data. Rekomendasi perbaikan yang diajukan mencakup penguatan konfigurasi header keamanan, validasi input/output, serta penghapusan informasi sistem yang tidak diperlukan. Penelitian ini diharapkan dapat berkontribusi dalam peningkatan keamanan sistem e-journals, serta menjadi dasar dalam penyusunan kebijakan keamanan dan pelaksanaan pengujian berkala yang mengacu pada standar internasional. Penelitian ini memberikan wawasan empiris tentang kerentanan spesifik pada OJS versi 2 di lingkungan universitas mulawarman yang belum pernah melakukan *penetration testing* dengan kerangka kerja menggunakan standar internasional, yang menjadi kontribusi orisinal dalam upaya peningkatan keamanan sistem publikasi akademik.

Kata kunci: penetration testing, owasp top 10, nist sp 800-115, keamanan website, e-journals

doi: 10.47002/metik.v9i1.1030

1. Pendahuluan

E-journal merupakan bentuk digitalisasi ilmu pengetahuan yang mempermudah pengguna dalam mengakses informasi serta mengelola kerja sama, baik melalui langganan antarperpustakaan, institusi, maupun penerbit e-journals lainnya. Dengan demikian, kebutuhan akan pengetahuan yang beragam dan terkini dapat terpenuhi [1]. Distribusi karya ilmiah dalam format digital juga memungkinkan proses publikasi yang lebih cepat, yang sangat penting untuk mendukung kemajuan ilmu pengetahuan di era yang berkembang pesat.

Pada penilaian karya ilmiah, salah satu aspek penting adalah karya tersebut harus dapat diakses secara online. Hal ini bertujuan untuk mencegah plagiat, sesuai dengan Kepmendiknas No. 17 Tahun 2010 tentang Pencegahan dan Penanggulangan Plagiat di Perguruan Tinggi. Selain itu, kebijakan ini diperkuat oleh Surat Edaran Dirjen DIKTI nomor 2050/E/T/2011, yang dikeluarkan pada 30 Desember 2011, terkait kewajiban unggah karya ilmiah dan jurnal [2].

Open Journal Systems (OJS) adalah sistem manajemen dan penerbitan jurnal ilmiah yang fleksibel, dikembangkan oleh *Public Knowledge Project* sejak tahun 2001. Platform ini memungkinkan pengelolaan artikel, proses peer review, dan indeksasi jurnal secara lebih efisien [3]. Universitas Mulawarman memanfaatkan OJS sebagai platform utama dalam penerbitan jurnal ilmiah daring untuk mendukung pengembangan ilmu pengetahuan dan penelitian.

Implementasi *Open Journal Systems* (OJS) di Universitas Mulawarman mencakup beberapa jurnal ilmiah yang dikelola oleh berbagai fakultas dan lembaga penelitian, memungkinkan akses terbuka terhadap publikasi akademik. Dengan fitur-fitur seperti manajemen artikel, proses peer review yang terstruktur, serta sistem pengarsipan yang terintegrasi, OJS membantu meningkatkan transparansi dan kredibilitas jurnal yang diterbitkan. Universitas Mulawarman menggunakan OJS versi 2 pada sistem *e-journals* yang digunakan.

Open Journal System 2 dapat di *setup* melalui beberapa tahapan pengaturan tampilan. Pemanfaatan pengaturan tersebut dapat memberikan navigasi yang membantu pengguna jurnal elektronik untuk mencari jurnal serta menjaga keamanan data di dalamnya. Berbeda dengan OJS2 dengan tampilan setup yang cukup panjang, OJS3 memiliki tampilan yang lebih ringkas, mudah dan flexible karena dibangun dengan prinsip mobile friendly. Tingkat keamanan data pada OJS3 juga diklaim lebih aman dari OJS2 karena celah keamanan OJS2 yang sering digunakan untuk jalur *hacking* sudah ditambal pada OJS3.

Penelitian yang dilakukan oleh [4] berjudul "Analisis Keamanan System Menggunakan *Vulnerability Assessment"* menunjukkan bahwa OJS2 memiliki banyak celah atau kerentanan keamanan. Kerentanan pada aplikasi website dapat terjadi akibat kesalahan dalam proses pengembangan atau perancangannya. Faktor-faktor yang memengaruhi kerentanan ini antara lain kesalahan dalam pengolahan input, penggunaan input yang tidak valid, serta desain aplikasi *website* yang kurang aman [5]. Untuk itu, penting bagi pengembang dan pemilik situs untuk melakukan upaya pencegahan dengan mengidentifikasi dan mengatasi potensi kerentanan sebelum serangan terjadi. Risiko yang terkait dengan penggunaan teknologi informasi dapat membahayakan aset aktual dan tidak berwujud [6].

Pencegahan keamanan sistem dapat dilakukan melalui uji kerentanan untuk mengidentifikasi kelemahan sebelum serangan terjadi [7]. OWASP adalah organisasi yang berfokus pada peningkatan keamanan aplikasi *website* dengan menyediakan sumber daya untuk membantu profesional keamanan dan pengembang mengatasi kerentanan [8]. Salah satu kontribusi OWASP yang paling terkenal adalah OWASP *Top* 10, yaitu daftar sepuluh risiko keamanan aplikasi *website* paling umum. Selain OWASP *Top* 10, terdapat standar keamanan lain yang juga berperan penting dalam pengujian keamanan aplikasi *website*, salah satunya adalah NIST SP 800-115.

NIST SP 800-115 adalah standar keamanan yang dikeluarkan oleh *National*

doi: 10.47002/metik.v9i1.1030

Institute of Standards and Technology, yang memberikan pedoman lengkap dalam melakukan pengujian keamanan aplikasi website, termasuk teknik pengujian penetrasi. Pemilihan standar NIST 800-115 di karenakan metodologi mempunyai tahapan yang membantu dalam melakukan analisa [9]. Metode ini dirancang untuk dalam merencanakan dan melakukan pengujian serta memeriksa teknis keamanan informasi, salah satunya dengan melakukan pengujian penetrasi yang terdiri dari 4 fase pengujian, yaitu fase *planning*, fase *discovery*, fase *attack*, dan fase *reporting* [10]. Pada fase *planning*, dilakukan identifikasi tujuan, ruang lingkup, dan aturan pengujian. Fase *discovery* bertujuan untuk mengumpulkan informasi tentang sistem target, baik secara pasif maupun aktif. Selanjutnya, fase *attack* melibatkan eksploitasi terhadap kerentanan yang ditemukan untuk menilai dampaknya secara nyata. Terakhir, fase *reporting* menyusun hasil temuan pengujian secara rinci, termasuk rekomendasi perbaikan yang dapat digunakan untuk meningkatkan keamanan sistem. Pendekatan ini memastikan bahwa pengujian dilakukan secara terstruktur, akuntabel, dan sesuai dengan standar praktik keamanan informasi.

Standarisasi NIST SP 800-115 dipilih karena menyediakan metode yang dapat diterapkan untuk melakukan *penetration testing*, serta langkah-langkah yang memberikan rekomendasi perbaikan [11]. Sedangkan OWASP *Top* 10, yang berisi daftar sepuluh kerentanan keamanan paling umum, bertujuan untuk membantu individu maupun organisasi dalam meninjau keamanan perangkat lunak. Dengan memahami daftar kerentanan ini, organisasi dapat mengambil keputusan yang tepat terkait mitigasi risiko keamanan yang ditemukan [12].

Penelitian sebelumnya oleh [13] menganalisis keamanan OJS Universitas Lancang Kuning menggunakan OWASP *Top* 10 tahun 2017 dan ISSAF, sedangkan dalam penelitian ini digunakan OWASP Top 10 tahun 2021 serta NIST SP 800-115 sebagai standar pengujian. Sementara itu, penelitian Darojat (2022) yang berjudul "*Vulnerability Assessment Website E-Government* dengan NIST SP 800-115 dan OWASP Menggunakan *Web Vulnerability Scanner*" menggunakan pendekatan *vulnerability scanning*, sedangkan penelitian ini menggunakan pendekatan *penetration testing* untuk analisis keamanan yang lebih mendalam. *Penetration testing* adalah praktik pengujian aset teknologi informasi untuk menemukan kerentanan keamanan yang dapat dieksploitasi oleh penyerang. Pengujian penetrasi dapat diotomatisasi dengan perangkat lunak atau dilakukan secara manual [14]. *Penetration testing* akan memberikan informasi rinci tentang ancamanan keamanan secara aktual, yang dapat dieksploitasi jika tercakup dalam aliran dan proses keamanan organisasi. Hal ini akan membantu organisasi untuk mengidentifikasi dengan cepat dan akurat, potensi kerentanan yang nyata [15].

Penelitian ini berjudul "*Penetration Testing Website E-journals* Dengan Metode NIST SP 800-115 Dan OWASP *Top* 10". Tujuan dari penelitian ini adalah untuk menganalisis kerentanan pada platform *e-journals* Universitas Mulawarman guna memastikan keamanan *website* serta melindungi data pengguna dan informasi ilmiah yang diakses melalui situs tersebut. Dengan menggunakan metode OWASP *Top* 10, penelitian ini akan mengidentifikasi potensi risiko keamanan, mengukur dampaknya, serta merekomendasikan langkah-langkah mitigasi yang tepat untuk meningkatkan keamanan situs *e-journals* Universitas Mulawarman. Penelitan ini menggunakan metode NIST SP 800-115, yang merupakan panduan untuk pengujian penetrasi, untuk memberikan pendekatan yang lebih komprehensif dalam mengidentifikasi dan mengatasi kerentanan yang ada. Secara ilmiah dan praktis untuk melakukan pengujian kerentanan pada OJS versi 2 di Universitas Mulawarman sangat penting mengingat platform ini masih digunakan meskipun diketahui memiliki sejumlah celah keamanan yang sering dimanfaatkan untuk *hacking*. Pengujian kerentanan pada OJS versi 2 di Universitas Mulawarman menjadi sangat penting, baik secara ilmiah maupun praktis. Hal ini dikarenakan platform tersebut masih aktif

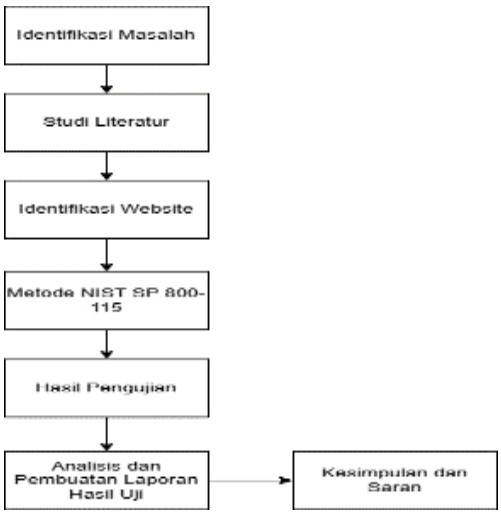
doi: 10.47002/metik.v9i1.1030

digunakan meskipun diketahui memiliki sejumlah celah keamanan yang sering dieksploitasi untuk peretasan. Penelitian ini mengisi kekosongan data mengenai tingkat keamanan spesifik pada implementasi OJS 2 di Universitas Mulawarman. Penelitian ini juga menyediakan rekomendasi mitigasi yang sesuai pada celah keamanan untuk mengatasi risiko tersebut, sehingga dapat berkontribusi pada perlindungan aset digital universitas dan menjaga integritas publikasi ilmiah.

2. Metode Penelitian

Metode yang digunakan dalam penelitian ini meliputi langkah-langkah kerja serta rangkaian kegiatan berdasarkan gambar 1, tahapan penelitian dilakukan sebagai berikut:

a. Identifikasi masalah
   Tahapan ini dilakukan untuk mengidentifikasi tingkat keamanan pada *website* e-*journals* Universitas Mulawarman.
b. Studi literatur
   Tahapan studi literatur dilakukan untuk menjelaskan teori-teori yang mendukung penelitian.
c. Identifikasi *website*
   Tahapan selanjutnya adalah identifikasi website, yang dilakukan untuk memahami struktur dan fitur-fitur yang ada pada website e-journals Universitas Mulawarman.
d. Metode NIST SP 800-115
   Tujuan dari tahapan ini adalah untuk mengevaluasi tingkat keamanan website dan memberikan rekomendasi perbaikan untuk mengurangi risiko potensi ancaman yang dapat mengancam integritas data dan sistem. Berikut tahapan pada metode NIST SP 800-115:
   1) *Planning*
      Pada fase ini dilakukan penentuan domain yang diuji, persetujuan dengan pihak pengelola *website*, serta penentuan metode pengujian menggunakan NIST SP 800-115 dengan parameter OWASP *Top* 10.
   2) *Discovery*
      Pada fase discovery terdapat dua tahapan utama, *information gathering* dan *vulnerability scanning*. Pada tahap *information gathering*, dilakukan pencarian informasi yang mencakup alamat IP, nama domain, layanan yang berjalan, versi perangkat lunak, hingga potensi celah keamanan pada *wesbsite*. Pada tahap vulnerability scanning, dilakukan proses untuk mengidentifikasi, menilai, dan melaporkan kelemahan keamanan dalam sistem atau aplikasi.
   3) *Attack*
      Tahap *Attack* merupakan salah satu tahapan dalam metode NIST SP 800-115 yang dilakukan untuk mengeksploitasi kerentanan pada website yang diuji menggunakan pendekatan *penetration testing*.
   4) *Reporting*
      Reporting merupakan tahapan mengenai penyampaian hasil penelitian dan penjelasan mengenai kesimpulan dari hasil pengujian dan penilaian keamanan akan dijabarkan secara rinci pada bagian kesimpulan.



Gambar 1. Alur Tahapan Penelitian

e. Hasil pengujian
   Setelah melaksanakan pengujian penetrasi dilakukan langsung ke server langsung pada web e-journals , hasil dari seluruh pengujian terhadap situs website e-journals Universitas Mulawarman akan diperoleh. Hasil tersebut akan menjadi acuan dalam menganalisis kegiatan pengujian, termasuk identifikasi celah keamanan yang ditemukan.
f. Analisis dan pembuatan laporan hasil uji

doi: 10.47002/metik.v9i1.1030

Analisis dilakukan setelah pengujian penetrasi atau *penetration testing* terhadap situs *website e-journals*. Analisis ini mencakup penilaian tingkat risiko, dampak yang mungkin ditimbulkan, serta rekomendasi langkah-langkah mitigasi yang sesuai berdasarkan standar keamanan yang sudah ditentukan, seperti OWASP *Top* 10 dan panduan dari NIST SP 800-115.

3. Hasil Penelitian

3.1. Tahap *Planning*

Tahap pertama dalam metode NIST SP 800-115 adalah tahap Planning. Tahapan ini dimulai dengan melakukan diskusi bersama pihak pengelola website untuk menyusun rencana simulasi pengujian atau penyerangan. Diskusi ini bertujuan untuk menyepakati ruang lingkup, tujuan, teknik pengujian, serta batasan-batasan yang harus dipatuhi selama proses uji penetrasi.

3.2. Tahap *Discovery*

Tahapan selanjutnya adalah *Discovery* yang dilakukan untuk mengumpulkan informasi yang terdapat pada *website* dengan domain e-journals.unmul.ac.id. Proses ini terdiri dari dua tahap dalam fase *discovery*, yaitu *information gathering* dan *vulnerability scanning*.

a. *Information Gathering*

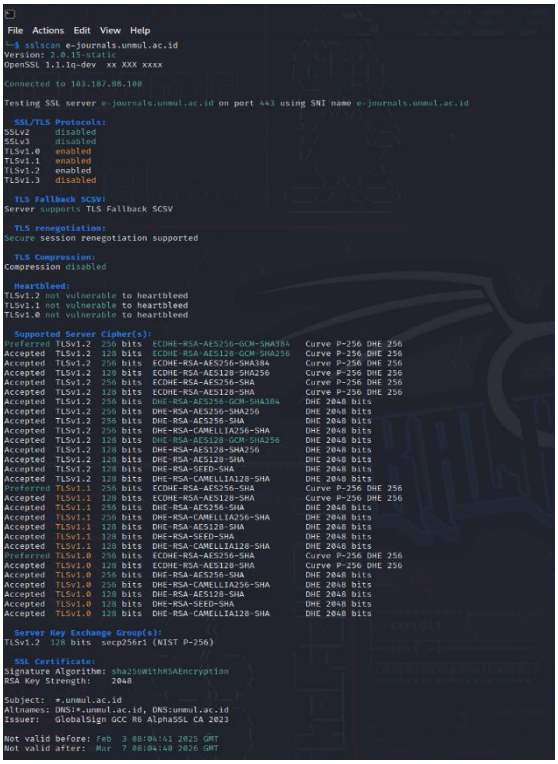
Tahap *information gathering* dilakukan untuk mengumpulkan informasi pada domain *website* yang akan diuji kerentanannya. *Tools* yang digunakan dalam proses *information gathering* adalah Nmap. Pengujian *port* dilakukan dengan cara memanggil nmap dan memasukan url setelah perintah dijalankan Nmap menampilkan *output* berupa satu *port* yang dideteksi yaitu *port* 80, dan juga informasi terkait *port* yang tidak ditampilkan berjumlah 998 dan memiliki status *filtered*. Hasil output dapat dilihat pada Tabel 1.

Table 1. Hasil pemindaian Nmap

Port	*State*	*Service*
80/tcp	*Open*	http

b. *Vulnerability Scanning*

Tahapan selanjutnya dari *discovery* yaitu *vulnerability scanning* atau merupakan analisis kerentanan. *Tools* yang digunakan pada tahapan *vulnerability scanning* yaitu OWASP ZAP V6 april 2025 dengan 6 *addons* baru dan SSLScan. Berdasarkan hasil pemindaian menggunakan OWASP ZAP, ditemukan 27 kerentanan, yang terdiri dari 1 kerentanan dengan risiko *high*, enam kerentanan dengan risiko *Medium*, tiga belas kerentanan bertipe *Low*, dan tujuh kerentanan bertipe *informational*. Selanjutnya pengujian mengunakan SSLScan. Berdasarkan hasil pemindaian menggunakan *tools* SSLScan, diketahui bahwa server e-journals.unmul.ac.id telah mengaktifkan protokol TLS versi 1.0, 1.1, dan 1.2, dengan TLSv1.2 sebagai protokol yang diprioritaskan (*preferred*). Sementara itu, protokol usang seperti SSLv2, SSLv3, dan TLSv1.3 telah dinonaktifkan. Meskipun penggunaan TLSv1.2 menunjukkan upaya untuk memenuhi standar keamanan modern, masih diaktifkannya TLSv1.0 dan TLSv1.1 menjadi potensi risiko karena kedua protokol tersebut telah dianggap tidak lagi aman oleh banyak organisasi keamanan siber. Selain itu, server mendukung berbagai cipher suite, termasuk algoritma yang kuat seperti ECDHE-RSA-AES256-GCM-SHA384, namun masih



Gambar 2. Hasil Scanning SSLScan

mengizinkan cipher lemah seperti DHE-RSA-

doi: 10.47002/metik.v9i1.1030

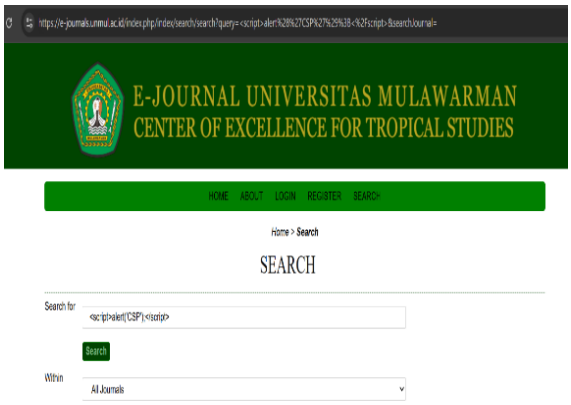
CAMELLIA128-SHA dan cipher non-GCM lainnya, yang secara kriptografi dinilai kurang aman. Hasil pengujian dapat dilihat pada Gambar 2.

3.3. Tahap *Attack*

Tahap selanjutnya, yaitu tahap *attack*, pada tahap ini menggunakan pendekatan *penetration testing* yang merupakan simulasi serangan. Pada metode NIST SP 800-115 tahapan ini bertujuan untuk melakukan mengetahui apakah kerentanan yang ditemukan dapat dieksploitasi. Berikut serangan yang dilakukan berdasarkan kerentanan yang ditemukan:

a. *Cross-Site Scripting*

Berdasarkan hasil pengujian pada Gambar 3 dibawah, menggunakan OWASP ZAP ditemukan terdapat tiga kerentanan yang dapat dimanfaatkan untuk melakukan serangan XSS yaitu *X-Content-Type-Options Header Missing*, *Cross-Domain JavaScript Source File Inclusion* dan *Content Security Policy* (CSP) *Header Not Set*. Pengujian ini dimulai dengan memasukan script pada kolom input yaitu : <script>alert('CSP');</script>, setelah dilakukan *inject* pada kolom *input* menggunakan sintaks tersebut. Dapat dilihat pada Gambar 3 website *e-journals* tidak menampilkan *alert* yang mengindikasikan bahwa serangan XSS atau *Cross-Site Scripting* tidak berhasil.



Gambar 4. Pengujian *Cross-Site Scripting*

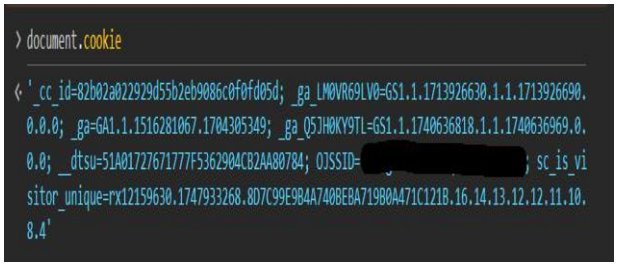
b. *Clickjacking*

Pada kerentanan *Missing* Anti-*Clickjacking Header*, seorang penyerang dapat membuat halaman website yang tampak menarik atau resmi, tetapi sebenarnya berisi elemen tersembunyi, seperti iframe yang memuat *website target*. Pada tahap ini, dilakukan pembuatan kode HTML sederhana dengan menambahkan tag iframe dan menyertakan URL dari yang dijadikan *website* target, seperti berikut <iframe src="urltarget/"></iframe>. Terlihat pada Gambar 4 bahwa simulasi serangan yang dilakukan berhasil akibat tidak ada proteksi keamanan seperti *X-Frame-Options*.

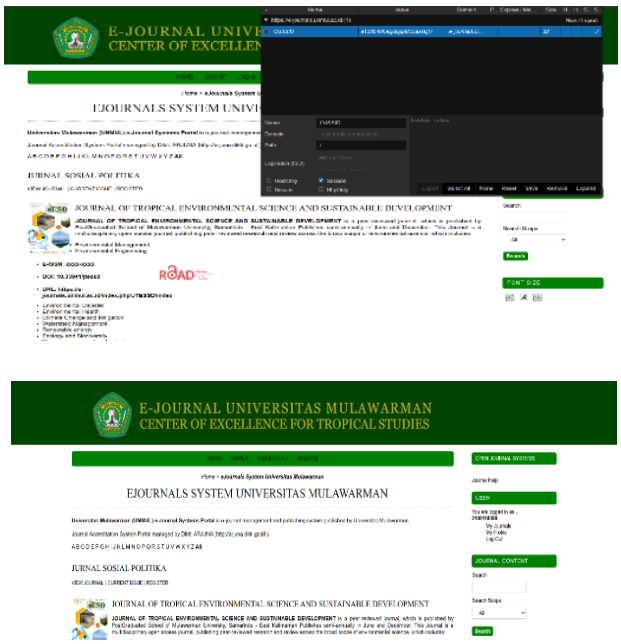
Gambar 4. Pengujian *Clickjacking*

c. *Session Hijacking*

Session hijacking adalah serangan di mana penyerang mencuri atau mengambil alih session ID milik pengguna yang sah untuk mendapatkan akses ke *website* tanpa harus *login*. Pada pengujian ini, penyerang dapat memeriksa *cookie* yang tersimpan di perangkat korban dengan mengetikkan



document.cookie pada konsol *browser*. Pada



Gambar 6. Hasil Login Menggunakan *Cookie*

doi: 10.47002/metik.v9i1.1030

METIK JURNAL VOLUME. 9 NOMOR.1 2025 ISSN-P 2442-9562 ISSN-E 2580-1503

Gambar 5 dapat dilihat *output* dari documdocument.cookie.

Tahap selanjutnya dapat dilihat pada Gambar 6 diatas penyerang dapat memasukan *value* dari OJSSID menggunakan ekstensi seperti *Cookie Manager*. Terlihat pada Gambar 7 diatas , tidak muncul peringatan atau notifikasi bahwa proses login gagal. Dapat disimpulkan bahwa isi dari *cookie* tersebut berisikan data ataupun hal sensitif lainya.

d. *Information Disclosure*

*Information disclos*ure merupakan kerentanan pada *website* dimana *website* menampilkan beberapa informasi yang seharusnya tidak ditampilkan pada *website*.

```
┌──(ragnar㉿kali)-[~]
└─$ curl -I https://e-journals.unmul.ac.id
HTTP/1.1 200 OK
Date: Tue, 15 Apr 2025 03:30:00 GMT
Server: Apache/2.2.15 (CentOS)
X-Powered-By: PHP/5.3.3
Set-Cookie: OJSSID=3ose64t2dv7jaeso4uht7b4i73; path=/; domain=e-journals.unmul.ac.id
Cache-Control: public
Connection: close
Content-Type: text/html; charset=utf-8
```

Gambar 7. Informasi *Website*

Pada Gambar 8 terlihat server yang digunakan yaitu Apache/2.2.15 (CentOS). Berdasarkan sumber cvedetails.com yang dapat dilihat pada Gambar 9, pada Apache/2.2.15 (CentOS) terdapat satu kategori kerentanan yaitu *Server-Side Request Forgery* (SSRF).

Version names

- Apache Software Foundation Apache HTTP Server 2.2.15
- cpe:2.3:a:apache:http_server:2.2.15:-:-:-:-:-:-:-
- cpe:/a:apache:http_server:2.2.15

Vulnerabilities by types/categories

Year	Overflow	Memory Corruption	Sql Injection	XSS	Directory Traversal	File Inclusion	CSRF	XXE	SSRF	Open Redirect	Input Validation
2015	0	0	0	0	0	0	0	0	0	0	0
2016	0	0	0	0	0	0	0	0	0	0	0
2017	1	1	0	0	0	0	0	0	0	0	1
2018	1	1	0	0	0	0	0	0	0	0	1
2021	1	2	0	0	0	0	0	0	0	0	0
2022	3	0	0	0	0	0	0	0	0	0	0
2023	0	0	0	0	0	0	0	0	0	0	0
2024	0	0	0	0	0	0	0	0	1	0	0
Total	6	4							1		2

Gambar 8. Kategori kerentanan

e. *Cross-Site Request Forgery*

Cross-Site Request Forgery merupakan serangan website yang memaksa pengguna yang telah di-autentikasi untuk melakukan tindakan yang tidak mereka inginkan di situs web yang tepercaya. Simulasi serangan dimulai dengan membuat HTML sederhana seperti membuat tag form dan juga memasukan url dari *website* target yang ditampilkan pada Gambar 10.

Gambar 9. *Source Code* HTML CSRF

```
1 <html>
2   <body onload="document.forms[0].submit()">
3     <form action="https://e-journals.unmul.ac.id/index.php/index/user/changePassword" method="POS
4 T">   <input type="password" name="oldPassword" value="12345678">
5       <input type="password" name="password" value="12345678">
6       <input type="password" name="password2" value="12345678">
7     </form>
8   </body>
9 </html>
```

Gambar 10. Hasil Simulasi *Cross-Site Request Forgery*

Simulasi serangan yang dilakukan tidak berhasil atau gagal dikarenakan tidak terdapat *alert* gagal ataupun berhasil serta tidak terjadi perubahan pada data target seperti yang terlihat pada Gambar 11. Hasil simulasi *Cross-Site Request Forgery* dinyatakan tidak valid.

3.4. Tahap *Reporting*

Tahap *reporting* merupakan tahap terakhir dalam metode NIST SP 800-115. Pada tahap sebelumnya, yang dilakukan untuk mengidentifikasi dan mengumpulkan berbagai temuan kerentanan selama proses pengujian keamanan. Berdasarkan hasil analisis, kerentanan yang paling banyak ditemukan adalah A05:2021 – *Security Misconfiguration* dengan total 9 kali kemunculan. Kerentanan ini mencerminkan adanya kesalahan dalam pengaturan sistem keamanan, seperti penggunaan konfigurasi default, fitur yang tidak diperlukan dibiarkan aktif, atau kesalahan dalam konfigurasi server dan aplikasi web.

Hal ini menunjukkan bahwa masih banyak sistem yang belum dikonfigurasi dengan benar sesuai standar keamanan yang direkomendasikan. Disusul oleh A01:2021 – *Broken Access Control* yang muncul sebanyak 8 kali, kerentanan ini menunjukkan adanya kelemahan dalam pembatasan akses, di mana pengguna dapat mengakses data atau fungsi yang seharusnya tidak mereka miliki. Ini merupakan indikasi bahwa sistem belum menerapkan kontrol akses yang efektif. Sementara itu, kerentanan lain seperti A02:2021 – *Cryptographic Failures*, A03:2021 – *Injection*, A04:2021 – Insecure Design, A06:2021 – V*ulnerable and Outdated Components*, dan A08:2021 –

doi: 10.47002/metik.v9i1.1030

Software and Data Integrity Failures masing-masing hanya muncul satu kali.

Pada Tabel 2 menyajikan hasil penetration testing berdasarkan kerentanan yang ditemukan pada tahap sebelumnya. Tabel ini mendokumentasikan hasil identifikasi kerentanan pada website target, mencakup nama serangan, dampak, status validasi, dan solusi yang disarankan. Berikut hasil dari tabel *penetration testing*:

Tabel 2. *Report Penetration Testing*

Nama Serangan	Dampak	Status Valid	Solusi
Cross-Site Scripting	Dampak yang dapat diakibatkan adalah penyerang dapat mengambil data sensitive dari situs.	Tidak Valid	1.Melakukan filtering khusus pada karakter. 2.Menambahkan validasi yang menjamin hanya input yang tepat yang dipilih.
Clickjacking	User akan membuka situs palsu yang dapat mengambil data milik user.	Valid	Menggunakan header X-Frame-Options: sameorigin atau deny.
Session Hijacking	Penyerang dapat bertindak sebagai pengguna sah tanpa perlu mengetahui kredensialnya.	Valid	Mengatur sesi timeout agar hanya dapat digunakan dalam kurun waktu tertentu.
Information Disclosure	Penyerang dapat mengetahui celah informasi yang tidak seharusnya ditunjukan oleh website	Valid	Menyembunyikan informasi terkait dengan informasi seperti versi pada php ataupun server yang digunakan.
Cross-Site Request Forgery	Serangan CSRF dapat menyebabkan pengambilan alih akun, transaksi tidak sah, dan perubahan pengaturan sistem	Tidak Valid	Developer harus menerapkan token CSRF pada setiap request yang sensitif, mengaktifkan pengaturan cookie SameSite, serta melakukan validasi terhadap header Origin atau Referer.

4. Kesimpulan

Berdasarkan hasil penelitian dan pengujian keamanan aplikasi web menggunakan metode NIST SP 800-115, dapat disimpulkan bahwa proses pengujian berhasil mengidentifikasi sejumlah kerentanan penting yang berpotensi membahayakan keamanan sistem. Identifikasi kerentanan dilakukan dengan mengacu pada standar OWASP Top 10 tahun 2021, dengan hasil pemindaian, ditemukan 27 kerentanan, yang terdiri dari 1 kerentanan dengan risiko *high*, enam kerentanan dengan risiko *Medium*, tiga belas kerentanan bertipe *Low*, dan tujuh kerentanan bertipe *informational* mencakup berbagai kategori seperti *Broken Access Control*, *Security Misconfiguration*, *Cryptographic Failures*, *Injection*, dan lainnya.

Melalui tahap *penetration testing*, beberapa kerentanan seperti *Cross Site-Scripting*, *Clickjacking*, *Session Hijacking*, Information Disclosure, dan *Cross-Site Forgery* berhasil dilakukan simulasi serangan dengan dampak yang signifikan terhadap keamanan data dan kontrol akses pengguna. Setiap kerentanan yang ditemukan telah diberikan rekomendasi perbaikan yang spesifik, seperti penguatan pengaturan keamanan header, validasi input/output, pengamanan pengelolaan sesi, serta penghapusan informasi sistem yang tidak perlu. Dengan hasil ini, diharapkan pengelola aplikasi dapat segera melakukan mitigasi untuk meningkatkan keamanan sistem dan mencegah potensi eksploitasi di masa mendatang.

doi: 10.47002/metik.v9i1.1030

5. Saran

Penelitian ini telah berhasil mengidentifikasi berbagai kerentanan pada website e-journals dengan menggunakan metode NIST SP 800-115 dan referensi dari OWASP Top 10. Sebagai pengembangan dari penelitian "*Penetration Testing Website E-Journals* dengan Metode NIST SP 800-115 dan OWASP *Top* 10", disarankan untuk melakukan pendekatan lanjutan dengan fokus pada analisis keamanan berbasis threat modeling. Metode ini memungkinkan identifikasi potensi ancaman sejak tahap perencanaan dan perancangan sistem, sehingga dapat membantu dalam membangun sistem yang lebih aman. Selain itu, penelitian selanjutnya juga dapat diarahkan pada simulasi serangan berbasis social engineering, seperti phishing terhadap pengguna sistem, untuk mengevaluasi aspek keamanan dari sisi pengguna atau administrator. Pendekatan ini akan memberikan gambaran yang lebih luas terhadap risiko keamanan yang tidak hanya berasal dari kelemahan teknis aplikasi, tetapi juga dari faktor manusia dan proses operasional yang mendukung sistem *website e-journals*.

6. Daftar Pustaka

[1] A. Ayatilla *Et Al.*, "Pemanfaatan E-Jurnal Di Kalangan Mahasiswa Fakultas Syariah," *Jurnal Pustaka Budaya*, Vol. 11, No. 2, 2024, [Online]. Available: https://journal.unilak.ac.id/index.php/pb/.

[2] I. Handayani *Et Al.*, "Optimalisasi Sistem Pengelolaan E-Journal Berbasis Open Journal System (Ojs) Menggunakan Framework Css Bootstrap Pada Instansi Dan Asosiasi," 2020.

[3] D. Saepuloh, "Implementasi Open Jurnal Sistem Versi 3 (Ojs 3) Di Dewan Riset Daerah Jakarta (Drd Jakarta) Open Journal System Version 3 (Ojs 3) Implementation At The Jakarta Regional Research Council." [Online]. Available: http://jurnal.drdjakarta.id/.

[4] I. Riadi, A. Yudhana, And P. Korspondensi, "Analisis Keamanan Website Open Journal System Menggunakan Metode Vulnerability Assessment," Vol. 7, No. 4, 2020, Doi: 10.25126/Jtiik.202071928.

[5] H. Herman, I. Riadi, Y. Kurniawan, And I. A. Rafiq, "Analisis Keamanan Website Menggunakan Information System Security Asessment Framework(Issaf)," *Jurnal Teknologi Informatika Dan Komputer*, Vol. 9, No. 1, Pp. 126–136, Mar. 2023, Doi: 10.37012/Jtik.V9i1.1439.

[6] C. Asari And Y. -, "Manajemen Risiko Sistem Informasi Mengacu Pada Nist Sp 800-30 Dan Nist Sp 800-53 Rev.5," *Jurnal Teknologi Dan Sistem Informasi Bisnis*, Vol. 5, No. 4, Pp. 420–430, Oct. 2023, Doi: 10.47233/Jteksis.V5i4.898.

[7] K. Ayu Suputri *Et Al.*, "Perbandingan Tools Vulnerability Scanning Pada Pengujian Sebuah Website," *Jurnal Informatik Edisi Ke*, Vol. 18, P. 2022, 2022, [Online]. Available: https://www.geeksforgeeks.org/rapidscan-the-multi-tool-web-vulnerability-scanner-in-kali-linux/.

[8] R. R. Yusuf And T. N. Suharsono, "Prosiding Seminar Sosial Politik, Bisnis, Akuntansi Dan Teknik (Sobat) Ke-5 Bandung, 28 Oktober 2023 Pengujian Keamanan Dengan Metode Owasp Top 10 Pada Website Eform Helpdesk," Oct. 2023.

[9] T. Astriani, A. Budiyono, And A. Widjajarto, "Analisa Kerentanan Pada Vulnerable Docker Menggunakan Scanner Openvas Dan Docker Scan Dengan Acuan Standar Nist 800-115," Vol. 8, No. 4, 2021, [Online]. Available: Http://Jurnal.Mdp.Ac.Id

[10] S. S. Anelia, J. Jayanta, And B. Hananto, "Uji Penetrasi Server Universitas Pqr Menggunakan Metode National Institute Of Standards And Technology (Nist Sp 800-115)," *Jurnal Ilmu Teknik Dan Komputer*, Vol. 7, No. 1, P. 34, Mar. 2023, Doi: 10.22441/Jitkom.2023.V7i1.005.

[11] W. Wardana, A. Almaarif, And A. Widjajarto, "Vulnerability Assessment And Penetration Testing On The Xyz Website Using Nist 800-115 Standard," Vol. 7, No. 1, 2022.

[12] E. Z. Darojat, E. Sediyono, And I. Sembiring, "Vulnerability Assessment Website E-Government Dengan Nist Sp 800-115 Dan Owasp Menggunakan Web Vulnerability Scanner," *Jurnal Sistem Informasi Bisnis*, Vol. 12, No. 1, Pp. 36–44, Sep. 2022, Doi: 10.21456/Vol12iss1pp36-44.

[13] L. Costaner And Dan Musfawati, "Analisis Keamanan Web Server Open

doi: 10.47002/metik.v9i1.1030

Journal System (Ojs) Menggunakan Metode Issaf Dan Owasp (Studi Kasus Ojs Universitas Lancang Kuning),” 2020.

[14] M. D. Purnomo And A. Chusyairi, “Sistematis : Jurnal Ilmiah Sistem Informasi Pengujian Keamanan Sistem Mengunakan Metode Penetration Testing Di Website Diskominfostandi Kota Bekasi,” *Oktober*, Vol. 1, No. 1, 2024, Doi: 10.69533.

[15] M. Hasibuan And A. M. Elhanafi, “Penetration Testing Sistem Jaringan Komputer Menggunakan Kali Linux Untuk Mengetahui Kerentanan Keamanan Server Dengan Metode Black Box,” *Sudo Jurnal Teknik Informatika*, Vol. 1, No. 4, Pp. 171–177, Dec. 2022, Doi: 10.56211/Sudo.V1i4.160.

.